LABORATUVAR 5 · ISP BANBURY · Kauçuk Mikseri

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad **Berfin Aslan** | Grup **Gece B** | Tarih **06.11.2026**

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Banbury Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

1) Bileşen var mı? Banbury PLC'sinin (Siemens / Allen Bradley / Mitsubishi) SBOM'unda ve PLC projesinde Component X aranır; belgede SBOM yok, bu yüzden ilk iş listeyi çıkarmak. **2) Sürüm etkileniyor mu?** Kayıtta 2.4 etkili; sahadaki PLC'de 2.4 çıkarsa evet.

3) Ulaşılabilir mi? PLC'ye ERP → i-MES → SCADA zinciri ve servis bağlantısı üzerinden gidilebiliyor; bölge ayrımı ve uzak erişim yöntemi belgede yok. Kanıtlanana kadar "etkileniyor" kabul edilir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, körlemesine durdurmam. Mikser tam karışım ortasında durursa ram, sıcak hamur ve boşaltma kapağında yeni tehlike doğar. Önce ulaşılabilirliği keserim: servis bağlantısı kapatılır, ERP / i-MES hattı geçici ayrılır, reçeteler yerelden çalışır. Sömürü izi varsa (Lab 6) mevcut batch güvenle bitirilip kontrollü duruş yapılır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. Canlı PLC'ye doğrudan yama yok. Önce PLC programı ve reçetelerin yedeği alınır, sonra yama test PLC'sinde / simülasyon ortamında denenir. Üretime planlı bakım duruşunda, geri dönüş (rollback) planı hazırken alınır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Etkileyebilir: kütüphane step cycle'ı, kapak kilidi veya ram kontrolünü işliyorsa. Anlamak için üretici sürüm notlarına ve yama öncesi/sonrası program farkına (diff, sağlama değeri) bakılır. Yama sonrası emniyet testleri tekrarlanır: kapak açıkken rotor start almaz, acil stop rotoru ve hidrolik enerjiyi keser, ram kilidi tutar, tepki süreleri aynı kalır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Bölge ayrımı ve firewall: PLC'ye yalnızca SCADA / jump server ulaşır, ERP doğrudan değil. Servis erişimi varsayılan kapalı, VPN + MFA + kişisel hesap. PLC'yi RUN / salt-okunur konuma alıp program yazmayı kapatmak, reçete limit kontrolü, PLC trafiği ve program değişiklik izleme, çevrimdışı yedek. Kapak kilidi ve acil stop PLC'den bağımsız emniyet rölesinde kalır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.